

Narrativa explicativa del marco GQM + PRAGMATIC para indicadores ISO 27001

1. Por qué mezclar GQM con PRAGMATIC

Los responsables de seguridad llevan años lidiando con dos problemas paralelos: por un lado, métricas que no se saben de dónde salen ni a qué objetivo responden; por otro, baterías de indicadores tan poco útiles que nadie los mira dos veces. El enfoque GQM resuelve lo primero asegurando trazabilidad entre objetivos, preguntas y métricas; el marco PRAGMATIC ayuda con lo segundo, separando las métricas interesantes de las que solo hacen ruido. [web:40][web:43][web:44][web:52]

Combinados, permiten construir un sistema de medición que no solo cumple con ISO/IEC 27001:2022 y sus exigencias de monitorización y medición, sino que también soporta objetivos nacionales, NIS2 y agendas de resiliencia. [web:43][web:46]

2. De los objetivos nacionales a la consola del SOC (trazabilidad GQM)

La idea básica de GQM es muy poco mágica: uno empieza por el objetivo (“reducir incidentes graves”, “mejorar resiliencia”, “cumplir NIS2”), se pregunta qué preguntas hay que contestar para saber si se avanza, y solo al final elige qué métricas medir. [web:40][web:51]

En nuestro caso:

- Los objetivos nacionales y regulatorios (por ejemplo, disminuir incidentes significativos, reforzar la resiliencia de operadores esenciales) se traducen en objetivos organizativos del SGSI.
- Estos objetivos se refinan en preguntas concretas: ¿detectamos lo suficientemente rápido?, ¿estamos por encima del apetito de riesgo?, ¿la cadena de suministro está bajo control?, etc.
- De esas preguntas derivan métricas técnicas: tiempos de detección, % de vulnerabilidades críticas resueltas, % de proveedores evaluados, etc.

El resultado es que cada número del cuadro de mando puede remontarse a un objetivo nacional o regulatorio, pasando por el objetivo corporativo y la pregunta que se pretendía responder.

3. De las métricas bonitas a las métricas útiles (PRAGMATIC)

El marco PRAGMATIC introduce un pequeño examen de conciencia para cada métrica candidata: ¿es predictiva o solo describe lo que ya ha pasado?, ¿es relevante para alguien que decide?, ¿sugiere acciones?, ¿refleja la realidad o se maquilla con facilidad?, ¿es comprensible?, ¿es suficientemente precisa?, ¿llega a tiempo?, ¿es independiente?, ¿es razonable en términos de coste? [web:44][web:49][web:52]

Aplicar este filtro obliga a:

- Retirar métricas que son caras y poco útiles.
- Reformular métricas para que sean más accionables o significativas.
- Priorizar aquellas que realmente ayudan a gestionar el riesgo, justificar inversiones o demostrar cumplimiento.

En la práctica, un catálogo razonable de métricas ISO 27001 no debería superar unas decenas de indicadores bien escogidos, cada uno con una puntuación PRAGMATIC aceptable.

4. Cómo se enlaza con ISO 27001 y NIS2

ISO/IEC 27001:2022 exige medir y evaluar el desempeño del SGSI, pero deja a cada organización la responsabilidad de elegir qué medir. ISO/IEC 27004 sugiere que esa elección no sea arbitraria, sino derivada de objetivos claros y apoyada en un modelo de medición coherente. [web:43][web:46]

NIS2 y otras regulaciones añaden la perspectiva externa: no basta con que la métrica tenga sentido para el CISO; también debe ayudar a demostrar diligencia, informar a autoridades cuando toque y encajar con informes de organismos como ENISA o los CERT nacionales. [web:43]

El marco GQM + PRAGMATIC encaja en este puzzle porque:

- Alinea objetivos internos con metas regulatorias y nacionales.
- Garantiza que las métricas elegidas están conectadas con controles y procesos del SGSI.
- Permite justificar por qué un conjunto concreto de métricas se considera razonable, suficiente y sostenible.

5. Cómo usar esta narrativa dentro de la organización

Esta narrativa puede utilizarse para:

- Convencer a la alta dirección de que no se trata de “inventar KPIs” sino de construir un sistema de medición con lógica.
- Explicar a los equipos técnicos por qué ciertas métricas se priorizan (y otras desaparecen sin lágrimas).
- Dar contexto a encuestas y ejercicios de autodiagnóstico, de forma que las personas que responden no vean las preguntas como un interrogatorio burocrático, sino como una herramienta para mejorar el SGSI.

Si, después de aplicar GQM + PRAGMATIC, la organización concluye que necesita menos métricas pero mejores, y que éstas se relacionan de forma clara con objetivos nacionales, regulatorios y de negocio, el esfuerzo habrá valido la pena.